

API Security Risk Analysis Report

Student Details

- Name: M.Bhavana
- Date: May 2026
- Task: API Security Risk Analysis

Objective

The objective of this task is to analyze security risks in a public API using Postman and identify possible vulnerabilities such as missing authentication, sensitive data exposure, input validation issues, and missing rate limiting.

Tools Used

- Postman
- Browser
- JSONPlaceholder Demo API
- MS Word / Google Docs

API Tested

<https://jsonplaceholder.typicode.com/>

Testing Methodology

The API endpoints were tested using GET and POST requests in Postman. Different inputs and repeated requests were analyzed to identify security weaknesses and improper configurations.

Findings

1.Sensitive Data Exposure

Risk Level

Medium

Description

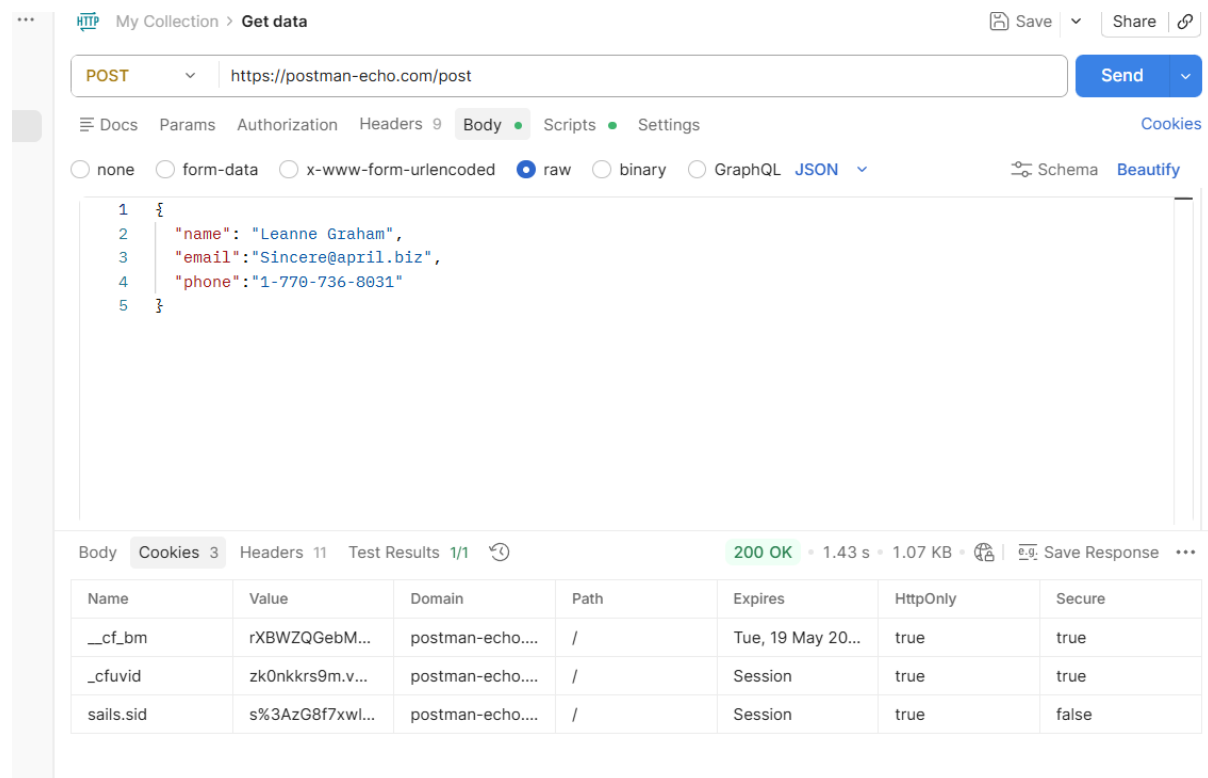
The API exposes user information such as email addresses and phone numbers.

Impact

Sensitive information may be misused by attackers.

Recommendation

Limit exposure of personal data and return only required fields



2. Missing Authentication

Risk Level

Medium

Description

API endpoints are accessible without authentication or authorization.

Impact

Unauthorized users may access API data.

Recommendation

Implement authentication using API keys or tokens

HTTP My Collection > Get data Save Share

GET https://jsonplaceholder.typicode.com/posts Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

none form-data x-www-form-urlencoded raw binary GraphQL JSON Schema Beautify

```
1 {
2   "title": "<script>alert('hack')</script>",
3   "body": "test",
4   "userId": 1
5 }
```

Body Cookies Headers 24 Test Results 1/1 200 OK • 42.17 s • 7.99 KB • Save Response

Key	Value
:status	200
date	Tue, 19 May 2026 14:30:46 GMT
content-type	application/json; charset=utf-8
access-control-allow-credentials	true
cache-control	max-age=43200
content-encoding	gzip
etag	W/"6b80-Ybsq/K6GwwqrYkAsFxqDXGC7DoM"
expires	-1
nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":360...

3. Improper Input Validation

Risk Level

Low

Description

The API accepts unsanitized input without proper validation.

Impact

This may lead to injection attacks or malicious data submission.

Recommendation

Validate and sanitize all user inputs before processing.

My Collection > Get data

POST

https://jsonplaceholder.typicode.com/posts

Send

Docs

Params

Authorization

Headers 8

Body

Scripts

Settings

none

form-data

x-www-form-urlencoded

raw

binary

GraphQL

Text

```
1 {
2   "title": "<script>alert('hack')</script>",
3   "body": "test",
4   "userId": 1
5 }
```

Body

Cookies

Headers 25

Test Results 0/1

201 Created

584 ms

1.2 KB

Save Response

Key	Value
:status	201
date	Wed, 20 May 2026 05:28:30 GMT
content-type	application/json; charset=utf-8
content-length	15
location	https://jsonplaceholder.typicode.com/posts/101
access-control-allow-credentials	true
access-control-expose-headers	Location
cache-control	no-cache
etag	W/"f-4jjw4Y8q22Yv1PV9m28FczJgizk"

4. Missing Rate Limiting

Risk Level

Low

Description

The API does not restrict repeated requests from users.

Impact

Attackers may abuse the API by sending excessive requests.

Recommendation

Implement rate limiting and monitoring mechanisms.

My Collection > Get data

GET

Docs Params Authorization Headers 6 **Body** Scripts Settings Cookies

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL

1

Body Cookies **Headers 24** Test Results 1/1 200 OK • 383 ms • 7.99 KB • Save Response ...

Key	Value
:status	200
date	Wed, 20 May 2026 05:20:20 GMT
content-type	application/json; charset=utf-8
access-control-allow-credentials	true
cache-control	max-age=43200
content-encoding	gzip
etag	W/"6b80-Ybsq/K6GwwqrYkAsFxqDXGC7DoM"
expires	-1
nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":360...

Conclusion

The API contains several common security risks including sensitive data exposure, missing authentication, lack of input validation, and absence of rate limiting. Applying proper security controls can improve API protection and reduce potential threats

References

- [JSONPlaceholder API](#)
- [Postman](#)

